ACXIOMCRM

CRM Project Documentation

Functional Requirements

1. Validation
2. Security
3. Authorization
4. API
5. Reports

Document Item	Details
Project	AcxiomCRM
Document Type	Functional & Technical Project Documentation
Primary Users	Admin, Manager, Sales Executive
Core Areas	Authentication, CRM, Sales, Follow-Up, Audit, API, Reporting
Validation	Client-side + Server-side + Business validation
Security	Password hashing, policy, lockout, authorization, audit logging
Status	Project Specification / Implementation Baseline

1. Document Purpose

This document defines the functional scope, module structure, validation requirements, security requirements, role-based authorization, workflows, REST API expectations, audit requirements, and reporting requirements for the AcxiomCRM application.

The document is intended to serve as a common reference for developers, testers, reviewers, and project evaluators.

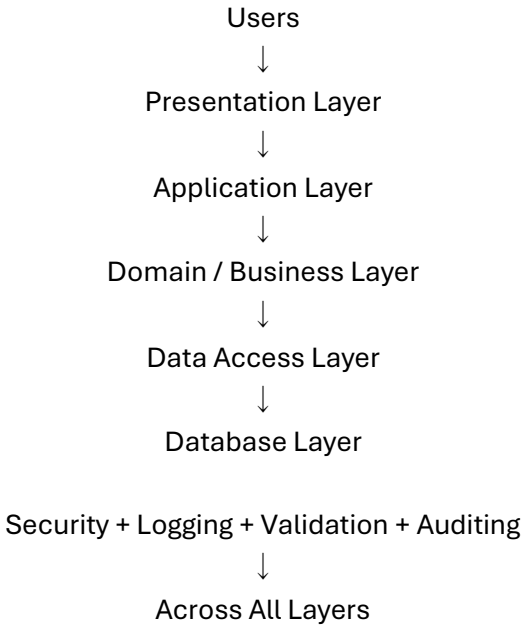
2. Complete Module Structure

S.NO	Module	Purpose
1	AcxiomCRM	Application shell, navigation, common UI, configuration and shared services.
2	Authentication & Authorization	Login, logout, password security, policy, lockout, roles and access control.
3	Dashboard	Role-based KPIs, summaries, charts, activities and sales pipeline visibility.
4	Customer Management	Customer master data, contacts, search, edit, status and customer history.
5	Lead Management	Lead capture, qualification, assignment, status, conversion and tracking.
6	Follow-Up Management	Follow-up scheduling, reminders, status, notes and activity history.
7	User & Role Management	User creation, role assignment, activation/deactivation and access administration.
8	Opportunity	Opportunity pipeline, amount, probability, expected close date and stage management.
9	Audit Log	Security and business activity tracking with user, timestamp, action and record details.
10	REST API	Secure APIs for customers, leads, opportunities, follow-ups, authentication and reporting data.
11	Reports	Customer, lead, follow-up, opportunity, sales pipeline, user activity and audit reports.

3. Application Architecture

The CRM application follows a layered architecture that separates presentation, application processing, business logic, data access, database, and security responsibilities. This design is technology-independent and can be implemented using different programming languages, frameworks, databases, and deployment platforms.

- Presentation Layer: Provides the user interface, screens, forms, dashboards, navigation, client-side validation, and user interaction.
- Application Layer: Handles application requests, service coordination, data transfer objects (DTOs), validation, workflow orchestration, and communication between the presentation layer and business layer.
- Domain/Business Layer: Contains CRM entities, core business rules, calculations, workflows, status transitions, business validations, and authorization-related rules.
- Data Access Layer: Provides a controlled mechanism for storing and retrieving application data. It contains database queries, data repositories, data-mapping components, and transaction handling where required.
- Database Layer: Stores persistent CRM data such as customers, leads, opportunities, follow-ups, users, roles, activities, and audit records. The database should use appropriate relationships, constraints, indexes, and normalization.
- Security Layer: Provides authentication, authorization, password protection, session/token management, access control, input protection, anti-forgery mechanisms, secure communication, and other application security controls.
- Cross-Cutting Services: Common services such as logging, exception handling, auditing, configuration management, caching, notifications, and monitoring can be shared across different application layers.



4. Functional Module Requirements

4.1 AcxiomCRM

- Provide a common application layout with responsive navigation, header, user menu, notifications and footer.
- Display menu items according to the logged-in user's role.
- Provide global search/filter patterns where useful.
- Use consistent Bootstrap styling, validation messages, alerts, confirmation dialogs and pagination.
- Protect authenticated pages from anonymous access.

4.2 Authentication & Authorization

- Provide Login and Logout.
- Authenticate users using username/email and password.
- Store only securely hashed passwords; never store plain-text passwords.
- Apply password policy before accepting a new password.
- Apply account lockout after repeated failed login attempts.
- Authorize resources using roles and, where required, ownership/business rules.
- Record successful and failed authentication events in the audit log.
- Use secure session/cookie configuration and anti-forgery protection for state-changing MVC requests.

4.3 Dashboard

- Show role-based KPIs such as total customers, open leads, open opportunities, pending follow-ups and pipeline amount.
- Admin dashboard may include user/activity/security statistics.
- Manager dashboard may show team pipeline, leads and opportunity performance.
- Sales Executive dashboard may show assigned customers, leads, opportunities and upcoming follow-ups.
- Provide date filters such as Today, This Week, This Month and Custom Range.
- Charts should be based on server-authorized data.

4.4 Customer Management

- Create, view, edit, search and filter customer records.
- Capture customer name, email, phone, address, status, assigned sales executive and notes.
- Prevent invalid email and phone formats.
- Support duplicate-checking rules where appropriate.
- Track creation, modification and important status changes.
- Allow authorized users to view customer history and related activities.

4.5 Lead Management

- Create and manage leads from prospective customers.
- Capture lead source, contact details, assigned sales executive, status, priority and notes.
- Support lead statuses such as New, Contacted, Qualified, Unqualified, Converted and Lost.
- Provide assignment to Sales Executive.
- Prevent invalid status transitions according to configured workflow.
- Support conversion of qualified leads into customer/opportunity records where applicable.

4.6 Follow-Up Management

- Create follow-up activities against customers, leads and opportunities.
- Capture follow-up date, subject, type, status, notes and assigned user.
- Support statuses such as Planned, Completed, Missed and Cancelled.
- Display upcoming and overdue follow-ups.
- Do not allow a new follow-up date earlier than today unless an authorized historical-entry process is explicitly supported.
- Record completion and rescheduling activity in audit history.

4.7 User & Role Management

- Create, edit, activate/deactivate and search application users.
- Assign exactly one primary role from Admin, Manager and Sales Executive unless multi-role support is explicitly implemented.
- Prevent unauthorized users from accessing user administration.
- Allow authorized administrators to reset passwords or trigger secure password reset workflows.
- Display account status and lockout status.
- Do not expose password hashes or security-sensitive fields in UI/API responses.

4.8 Opportunity

- Create and manage sales opportunities.
- Capture opportunity name, customer, owner, stage, amount, probability, expected close date, source and notes.
- Support pipeline stages such as Qualification, Proposal, Negotiation, Won and Lost.
- Calculate/derive weighted pipeline where required using Amount × Probability / 100.
- Require amount greater than zero for active sales opportunities.
- Require probability from 0 through 100.
- Expected Close Date cannot be in the past for active opportunities.

4.9 Audit Log

- Capture login success/failure, logout, create, update, delete, role changes, password/security events and important status changes.
- Record user, timestamp, action, module, record identifier, result and relevant metadata.

- Audit records should be append-oriented and protected from unauthorized modification/deletion.
- Provide filtering by user, module, action and date range.

4.10 REST API

- Expose secured endpoints for CRM resources using REST conventions.
- Use DTOs instead of exposing database entities directly.
- Validate input at API boundaries.
- Return appropriate HTTP status codes such as 200, 201, 400, 401, 403, 404 and 409 where applicable.
- Apply authorization to every protected endpoint.
- Document endpoints, request/response models and error responses.
- Do not return passwords, password hashes, security tokens or unnecessary internal database fields.

4.11 Reports

- Customer Report: customer list, status, owner and creation date.
- Lead Report: lead source, status, owner and conversion information.
- Follow-Up Report: planned, completed, missed and overdue activities.
- Opportunity Report: stage, amount, probability and expected close date.
- Pipeline Report: stage-wise and owner-wise pipeline amount.
- Sales/Conversion Report: lead conversion and opportunity outcome metrics.
- User Activity Report: user actions and activity counts.
- Audit Report: security and business audit events.
- Reports should support filters, sorting, pagination and export where implemented.

5. Validation Requirements

AcxiomCRM shall implement validation at multiple levels. Client-side validation improves user experience, but server-side validation remains mandatory because client-side rules can be bypassed.

5.1 Client-Side Validation — Required

Validation Type	Requirement	Example
Required	Mandatory fields must not be empty.	Customer Name is required.
Email	Validate email format.	user@example.com
Phone	Validate allowed phone pattern/length.	10-digit Indian mobile format, if that is the project rule.
Length	Enforce minimum/maximum character limits.	Name: configured maximum length.
Date	Validate valid date and configured date rules.	Expected Close Date.
Numeric	Validate numeric format, range and precision.	Opportunity Amount > 0.

5.2 Server-Side Validation — Mandatory

- Repeat all security- and business-critical validations on the server.
- Validate model state before database operations.
- Validate foreign keys and referenced records.
- Reject unauthorized record modifications even when a user manipulates browser requests.
- Return user-friendly validation messages without exposing database internals.

5.3 Business Validation Rules

Field/Area	Rule	Validation Category
Expected Close Date	Cannot be in the past for an active Opportunity.	Business validation
Opportunity Amount	Must be greater than 0.	Numeric + business validation
Probability	Must be between 0 and 100 inclusive.	Numeric + business validation
Follow-Up Date	Cannot be earlier than today for a new/planned follow-up.	Date + business validation
Email	Must be present where required and follow valid email format.	Email validation
Phone	Must follow the configured phone format and length.	Phone validation
Required fields	Mandatory business fields must be supplied before save.	Required validation
Length	Text values must remain within configured database/UI limits.	Length validation

5.4 Recommended Validation Examples

- Opportunity Amount = 0 → reject with: “Opportunity Amount must be greater than 0.”
- Probability = 101 → reject with: “Probability must be between 0 and 100.”
- Expected Close Date = yesterday → reject with: “Expected Close Date cannot be in the past.”
- Follow-Up Date = yesterday → reject with: “Follow-up date cannot be earlier than today.”
- Email = invalid format → reject with: “Enter a valid email address.”
- Phone = invalid length/characters → reject with: “Enter a valid phone number.”
- Required field blank → reject with a field-specific required message.
- Text exceeds maximum length → reject before database save.

6. Authentication & Security Specification

6.1 Authentication Features

Feature	Requirement
Login	Authenticate active users using approved credentials.
Logout	Terminate authenticated session/cookie and redirect safely.
Password Hashing	Use a strong adaptive password hashing mechanism; never store plain text.
Password Policy	Enforce configurable minimum length and complexity rules.
Lockout	Temporarily lock an account after repeated failed authentication attempts.
User Management	Authorized administrators can manage user status and roles.
Authorization	Use role and resource-level authorization for protected operations.
Audit	Record authentication/security events without storing sensitive credentials.

6.2 Recommended Password Policy

- Minimum length: 8 characters (or higher if the organization's security standard requires it).
- Require a combination of character classes where appropriate.
- Do not allow storage or display of plain-text passwords.
- Do not log passwords, password hashes, reset tokens or authentication secrets.
- Require secure password change/reset flows.
- Consider preventing reuse of recent passwords if required by the project security standard.

6.3 Lockout

- Track failed login attempts.
- After a configurable threshold, lock the account for a configurable duration.
- Reset failed-attempt count after successful authentication according to the security policy.
- Allow authorized administration/unlock through a controlled process.
- Audit lockout and unlock events.

7. Role-Based Authorization

The initial role model contains three roles: Admin, Manager and Sales Executive. Authorization should be enforced on the server, not only by hiding navigation links.

Role	Access Scope
Admin	Full application administration, users/roles, audit logs, configuration, all CRM records and reports.
Manager	Team/customer/lead/opportunity/follow-up management and management reports; no unrestricted security administration.
Sales Executive	Assigned customers, leads, opportunities and follow-ups; access to permitted sales dashboards/reports.

7.1 Suggested Permission Matrix

Module	Admin	Manager	Sales Executive
Dashboard	Full	Team	Own/Assigned
Customers	Full	Team/Business Scope	Own/Assigned
Leads	Full	Team	Own/Assigned
Follow-Ups	Full	Team	Own/Assigned
Opportunities	Full	Team	Own/Assigned
User Management	Full	View/limited administration if configured	No
Role Management	Full	No	No
Audit Log	Full	Limited view if configured	No
REST API	Authorized endpoints	Authorized endpoints	Authorized endpoints
Reports	All	Management/team reports	Own/assigned reports

8. Core CRM Workflows

Lead-to-Customer

1. Create Lead
2. Assign Lead
3. Contact Lead
4. Qualify
5. Convert to Customer/Opportunity
6. Record conversion in Audit Log

Opportunity

1. Create Opportunity
2. Set Amount

3. Set Probability
4. Set Expected Close Date
5. Move through Pipeline Stages
6. Mark Won/Lost
7. Capture final outcome

Follow-Up

1. Create Follow-Up
2. Set Date
3. Assign User
4. Complete/Missed/Reschedule
5. Update related CRM record
6. Audit action

User Administration

1. Create User
2. Assign Role
3. Set Active/Inactive
4. Apply Password/Lockout Policy
5. Audit security change

9. Core Data Entities

Entity	Representative Fields
User	UserId, Name, Email, PasswordHash, RoleId, IsActive, FailedLoginCount, LockoutEnd, CreatedDate
Role	RoleId, RoleName
Customer	CustomerId, Name, Email, Phone, Address, Status, OwnerId, CreatedDate, ModifiedDate
Lead	LeadId, Name, Email, Phone, Source, Status, Priority, OwnerId, CreatedDate
FollowUp	FollowUpId, RelatedType, RelatedId, FollowUpDate, Subject, Status, AssignedUserId, Notes
Opportunity	OpportunityId, CustomerId, Name, Stage, Amount, Probability, ExpectedCloseDate, OwnerId, Notes
AuditLog	AuditLogId, UserId, Module, Action, RecordId, Timestamp, Result, Details

10. REST API Specification

Method	Endpoint	Purpose	Access
POST	/api/auth/login	Authenticate user	Public/Rate limited
POST	/api/auth/logout	Logout/session termination	Authenticated
GET	/api/customers	List/search customers	Authorized
POST	/api/customers	Create customer	Authorized
GET	/api/customers/{id}	Get customer	Authorized
PUT	/api/customers/{id}	Update customer	Authorized
DELETE	/api/customers/{id}	Delete/deactivate customer	Authorized
GET	/api/leads	List/search leads	Authorized
POST	/api/leads	Create lead	Authorized
GET	/api/opportunities	List/search opportunities	Authorized
POST	/api/opportunities	Create opportunity	Authorized
GET	/api/followups	List follow-ups	Authorized
POST	/api/followups	Create follow-up	Authorized
GET	/api/reports/pipeline	Pipeline report data	Manager/Admin or configured scope

10.1 API Security

- Require authentication for protected endpoints.
- Apply role/permission checks at endpoint/service level.
- Validate every request payload.
- Use HTTPS in deployed environments.
- Implement appropriate rate limiting/throttling for authentication-sensitive endpoints.
- Return consistent error objects without exposing stack traces or database details.

11. Reporting Requirements

Report	Key Data	Access
Customer Report	Customer, status, owner, created date	Admin/Manager/authorized user
Lead Report	Source, status, owner, conversion	Admin/Manager/Sales scope
Follow-Up Report	Date, status, owner, overdue activities	All authorized roles
Opportunity Report	Stage, amount, probability, expected close date	All authorized roles
Pipeline Report	Stage-wise, owner-wise, weighted pipeline	Admin/Manager; scoped sales view
Conversion Report	Leads converted vs not converted	Admin/Manager; scoped sales view
User Activity Report	Activity/action counts by user	Admin/Manager where permitted
Audit Report	Security and business events	Admin; restricted access

12. UI/UX Standards

- Use responsive Bootstrap layout for desktop and tablet views.
- Keep navigation consistent across modules.
- Show inline validation messages next to invalid fields.
- Use clear success/error/warning notifications.
- Use confirmation dialogs for destructive actions.
- Provide search, filtering, sorting and pagination on list pages.
- Use accessible labels, keyboard-friendly controls and meaningful validation messages.
- Do not expose technical exception messages to end users.

13. Testing & Acceptance Checklist

Area	Acceptance Criteria
Authentication	Valid login works; invalid credentials are rejected; logout works.
Password Security	Password is never stored as plain text; policy is enforced.
Lockout	Repeated failed logins trigger configured lockout.
Authorization	Users cannot access unauthorized pages, records or APIs by manually changing URLs/requests.
Client Validation	Required, email, phone, length, date and numeric validation works before submission.
Server Validation	Invalid/tampered requests are rejected on the server.
Opportunity	Amount > 0, probability 0–100, and close-date rule are enforced.
Follow-Up	Follow-up date cannot be earlier than today for new/planned activities.
Audit	Important security and business actions create audit entries.
API	Endpoints return correct status codes and enforce authorization.
Reports	Filters and role-based data visibility are respected.

14. Security Checklist

- Password hashing enabled.
- Password policy enabled.
- Account lockout enabled.
- Role-based authorization enabled.
- Server-side validation enabled.
- Anti-forgery protection enabled for state-changing MVC forms.

- Sensitive information excluded from logs.
- HTTPS used in production/deployment.
- API authorization and input validation enabled.
- Audit logging enabled for security-sensitive actions.
- Least-privilege access applied to roles.
- Database credentials stored securely and not hard-coded in source control.

15. Recommended Implementation Sequence

1. Create solution structure and database.
2. Create User and Role entities and authentication.
3. Implement Admin/Manager/Sales Executive authorization.
4. Create common layout/navigation and dashboard shell.
5. Implement Customer Management.
6. Implement Lead Management.
7. Implement Follow-Up Management.
8. Implement Opportunity Management.
9. Add client-side and server-side validation.
10. Implement Audit Log.
11. Implement REST APIs and secure API authorization.
12. Implement Reports and dashboard KPIs.
13. Execute security, validation, workflow and role-based testing.
14. Prepare deployment configuration and production security settings.

16. Final Project Scope

AcxiomCRM is defined as a role-based CRM application covering the complete customer-sales lifecycle from lead capture through follow-up and opportunity management, with authentication, authorization, auditability, validation, APIs and reporting. The project should demonstrate both functional CRM capabilities and production-oriented engineering practices.

The mandatory quality requirements are: client-side validation for Required, Email, Phone, Length, Date and Numeric inputs; server-side enforcement of critical rules; business validation for opportunity and follow-up dates/values; secure authentication; password hashing; password policy; account lockout; role-based authorization; audit logging; and secured REST APIs.

17 Business Scenario

AcxiomCRM is a web-based CRM application used by a sales organization to manage customers, leads, opportunities, follow-ups, activities, sales pipeline, users and roles, and audit logs. Sales users manage their assigned CRM records while managers monitor the complete sales pipeline through a dashboard.

17.2 Mandatory Module Tree

```
AcxiomCRM
│
├── Authentication
│   ├── Login
│   ├── Register
│   ├── Logout
│   └── Access Control
│
├── Dashboard
│   ├── Total Customers
│   ├── Total Leads
│   ├── Open Opportunities
│   ├── Won Opportunities
│   ├── Lost Opportunities
│   ├── Sales Pipeline
│   └── Charts
│
├── Customer Management
│   ├── Create
│   ├── Edit
│   ├── Details
│   ├── Delete
│   └── Search
│
├── Lead Management
│   ├── Create
│   ├── Edit
│   ├── Details
│   ├── Delete
│   ├── Lead Status
│   └── Lead Conversion
│
├── Opportunity Management
│   ├── Create
│   ├── Edit
│   ├── Details
│   ├── Delete
│   └── Sales Pipeline
│
├── Follow-Up
│   ├── Schedule Follow-Up
│   ├── Complete Follow-Up
│   └── Pending Follow-Ups
│
├── Activity Management
│   ├── Call
│   ├── Meeting
│   ├── Email
│   └── Task
│
├── User & Role Management
│   ├── Users
│   ├── Roles
│   └── Permissions
│
```

```
└── Audit Log
    ├── Login
    ├── Create
    ├── Update
    └── Delete
```

17.3 Database Design — Mandatory Entities

Table	Required Fields
Customer	CustomerId, CustomerCode, CustomerName, Email, Phone, CompanyName, Address, City, State, Status, CreatedDate, CreatedBy
Lead	LeadId, LeadCode, LeadName, Email, Phone, CompanyName, Source, Status, ExpectedValue, CreatedDate, AssignedTo
Opportunity	OpportunityId, OpportunityName, CustomerId, LeadId, Amount, Stage, Probability, ExpectedCloseDate, Status, CreatedDate, AssignedTo
FollowUp	FollowUpId, CustomerId, LeadId, FollowUpDate, FollowUpType, Remarks, Status, AssignedTo
Activity	ActivityId, ActivityType, Subject, Description, ActivityDate, CustomerId, LeadId, AssignedTo, Status
AuditLog	AuditLogId, UserId, Action, EntityName, RecordId, OldValue, NewValue, CreatedDate, IpAddress

17.4 Authentication Database Requirement

Do not create a custom password table for authentication. Use ASP.NET Core Identity for users, password hashing, claims/roles, authentication cookies, password policy and lockout.

- Use IdentityUser/IdentityRole or appropriately extended application identity classes.
- Store only framework-managed password hashes.
- Do not expose password hashes in MVC views, DTOs, API responses or logs.

17.5 Mandatory Customer Validation

- Customer Name is required and has a maximum length.
- Email is required and must have a valid email format.
- Phone is required and must satisfy the configured phone format.
- Email uniqueness must be enforced.
- Phone uniqueness must be enforced.
- Duplicate customer creation must be prevented.

17.6 Mandatory Lead Validation

- Lead name is mandatory.
- Expected value must be within the configured numeric range.
- Lead status is mandatory and must come from a valid status set.
- Lead email and phone must follow the project's common validation rules.

17.7 Mandatory Business Validation

Rule	Requirement
Email	Must be valid and unique where uniqueness is required.
Phone	Must be valid and unique where uniqueness is required.
Opportunity Amount	Cannot be negative; active opportunities should require Amount > 0.
Expected Close Date	Cannot be in the past for an active opportunity.
Required Fields	Cannot be empty.
Duplicate Customer	Same business-identifying customer cannot be created twice.
Lead Status	Only valid configured statuses can be selected/transmitted.
Follow-Up Date	Cannot be earlier than today for a new/planned follow-up.
Probability	Must be between 0 and 100.

17.8 Client-Side and Server-Side Validation

The assignment requires both client-side and server-side validation. Client-side validation provides immediate feedback, while server-side validation protects the application from manipulated HTTP requests.

- Required validation
- Email validation
- Phone validation
- String length validation
- Date validation
- Numeric/range validation
- Business validation on the server

17.9 Mandatory Security Implementation

Security Area	Mandatory Requirement
Authentication	Login, Register, Logout, session/cookie management and unauthorized-access protection.
Password Security	Use ASP.NET Core Identity password hashing; never store plain-text passwords.
Authorization	Use role-based and server-side authorization.
Anti-Forgery	Protect state-changing MVC POST forms with ValidateAntiForgeryToken.
SQL Injection	Use Entity Framework Core parameterization/query APIs; do not concatenate user input into SQL.
Server Validation	Validate every important request on the server.
Client Validation	Use unobtrusive/Razor validation for user experience.
Audit Logging	Record important security and business operations.

17.10 Role-Based Authorization

Role	Required Scope
Admin	Full administration, users, roles, audit logs, CRM records, reports and system management.
Manager	Monitor/manage team CRM data, pipeline, follow-ups and reports; no unrestricted security administration.
SalesExecutive	Manage assigned customers, leads, opportunities, follow-ups and activities.

17.11 Dashboard — Mandatory

After successful login, the user should be redirected to the AcxiomCRM Dashboard according to the user's authorized scope.

Dashboard Card	Definition
Total Customers	Count of customers visible to the user.
Total Leads	Count of leads visible to the user.
Open Leads	Leads that are not closed/lost/converted.
Total Opportunities	Count of opportunities in scope.
Open Opportunities	Opportunities currently open.
Won Opportunities	Won opportunity count.
Lost Opportunities	Lost opportunity count.
Total Pipeline Value	Sum of eligible open opportunity amounts.

17.12 Dashboard Charts — Chart.js

Chart	Required Data
Lead Status	New, Contacted, Qualified, Lost, Converted
Opportunity Pipeline	Qualification, Proposal, Negotiation, Won, Lost
Monthly Sales	Monthly sales/outcome totals for the configured reporting period

17.13 Search and Filtering

Page	Required Search/Filter
Customers	Customer Name, Email, Phone, Company
Leads	Lead Name, Company, Status, Assigned User
Opportunities	Opportunity Name, Customer, Stage, Status
Follow-Ups	Date, Status, Assigned User, Related Customer/Lead
Activities	Activity Type, Date, Status, Assigned User

17.14 REST API — Mandatory

At least one API controller is mandatory. The recommended implementation exposes Customers, Leads and Opportunities.

Method	Endpoint	Operation
GET	/api/customers	Get customers
GET	/api/customers/{id}	Get customer by ID
POST	/api/customers	Create customer
PUT	/api/customers/{id}	Update customer
DELETE	/api/customers/{id}	Delete/deactivate customer
GET	/api/leads	Get leads
POST	/api/leads	Create lead
GET	/api/opportunities	Get opportunities
POST	/api/opportunities	Create opportunity

- Use DTOs rather than exposing EF entities directly.
- Validate API payloads.
- Apply authentication/authorization to protected endpoints.
- Return appropriate HTTP status codes.
- Do not return password or security-sensitive information.

17.16 Audit Logging Requirements

Event	Example
Login	User successfully logs in.
Failed Login	Invalid login attempt/lockout event.
Create	Customer/Lead/Opportunity created.
Update	Customer/Lead/Opportunity updated.
Delete	Authorized deletion/deactivation.
Role Change	User role changed.
Security	Password/security-related administrative event without storing secrets.

Audit records should capture UserId, Action, EntityName, RecordId, OldValue, NewValue, CreatedDate and IpAddress where available.

17.17 Minimum Evaluation Criteria

Evaluation Area	Minimum Expectation
CRUD	All required modules support functional create/read/update/delete or appropriate deactivation.
Validation	Client-side and server-side validation demonstrated.
Business Rules	Opportunity, lead and follow-up rules implemented.
Authentication	Identity login/logout/register works.
Authorization	Admin, Manager and SalesExecutive access differs.

Dashboard	Required cards and charts work.
Search	Required pages support search/filter.
REST API	At least Customer/Lead/Opportunity APIs work.
Audit	Important operations are logged.
Architecture	Controllers, Models, Data, Services, ViewModels and Views are organized.
Security	No plain-text passwords; anti-forgery and protected endpoints implemented.

17.19 Final Acceptance Scenario

1. Open AcxiomCRM without authentication → protected CRM pages must not be accessible.
2. Register/login with a valid test user → user reaches the Dashboard.
3. Create a Customer with invalid email/phone → client-side validation appears and save is blocked.
4. Bypass browser validation with a crafted request → server-side validation still rejects invalid data.
5. Create an Opportunity with Amount <= 0 → rejected.
6. Create an Opportunity with Probability > 100 → rejected.
7. Set Expected Close Date in the past → rejected for an active opportunity.
8. Create a Follow-Up dated before today → rejected for a new/planned follow-up.
9. Login as SalesExecutive → only authorized/assigned sales scope is accessible.
10. Login as Manager → team pipeline/report access is available.
11. Login as Admin → user/role/audit administration is available.
12. Create/update/delete a CRM record → appropriate audit entry is generated.
13. Call /api/customers → authorized JSON response is returned.
14. Open Dashboard → KPI cards and Chart.js charts display authorized data.

17.20 Project Completion Standard

A submission is not considered complete if it is only a database CRUD application. The student must demonstrate CRM workflows, client-side validation, server-side validation, business rules, secure authentication, role-based authorization, dashboard analytics, audit logging, REST API functionality and a structured application architecture.